

Welche Tools darf Ihr KI-Agent nutzen?

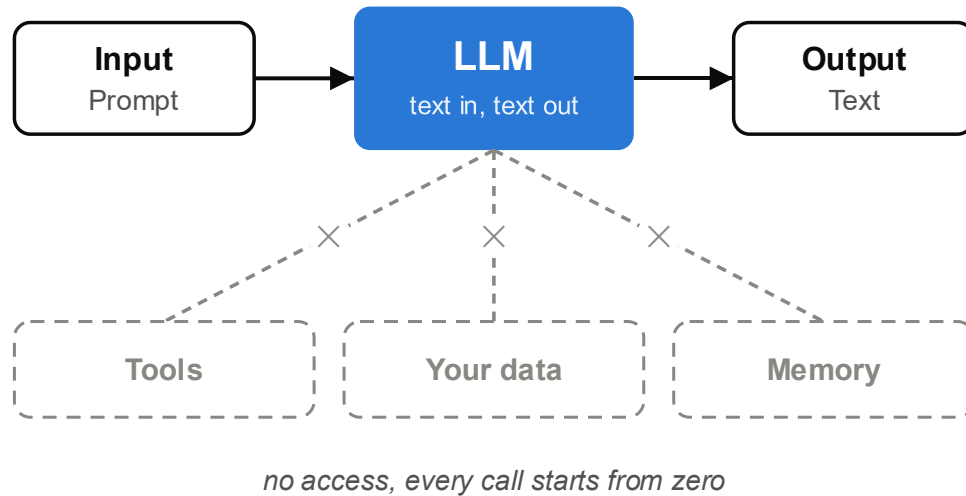
MCP in der Praxis: Use Cases finden und Server sicher prüfen

Jill Barvencik · David Goll
KI-Servicezentrum Berlin-Brandenburg (HPI)
09.09.2026

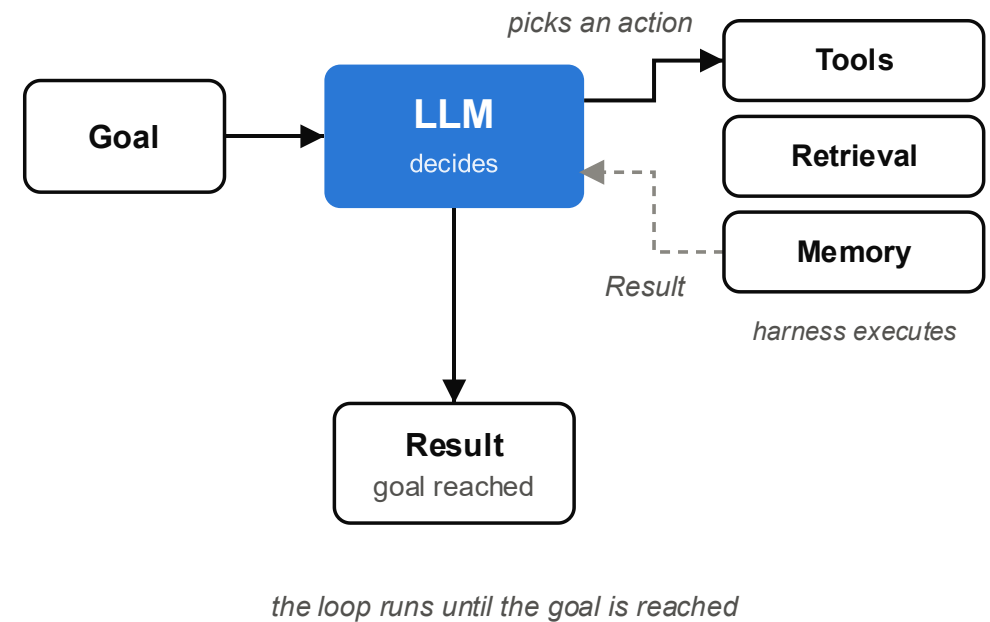
20 Min. Konzepte → 10 Min. Beispiel → 20 Min. Ihr eigener Use Case → 10 Min. Diskussion

Was ist ein Agent?

The LLM on its own

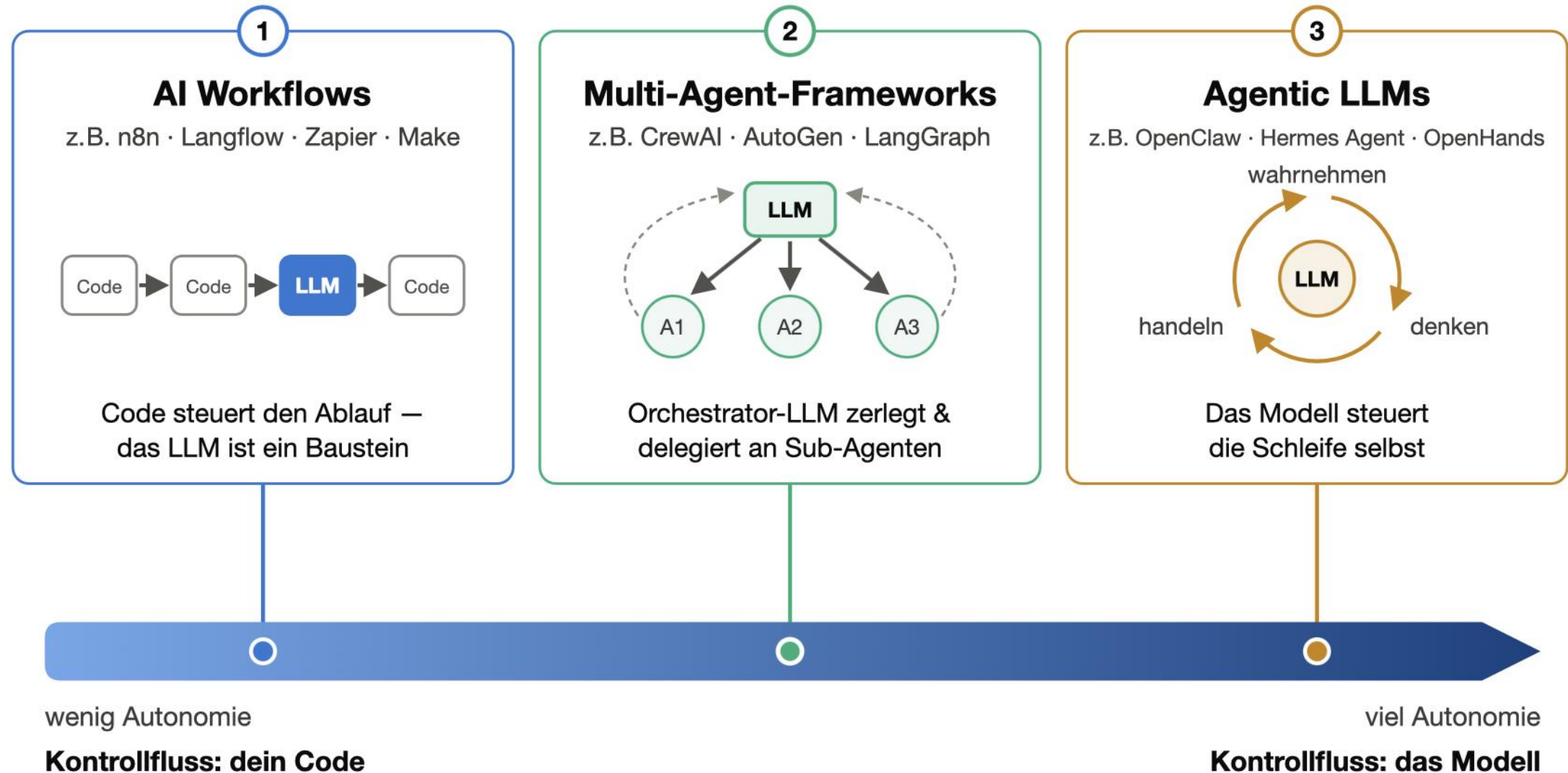


The agent

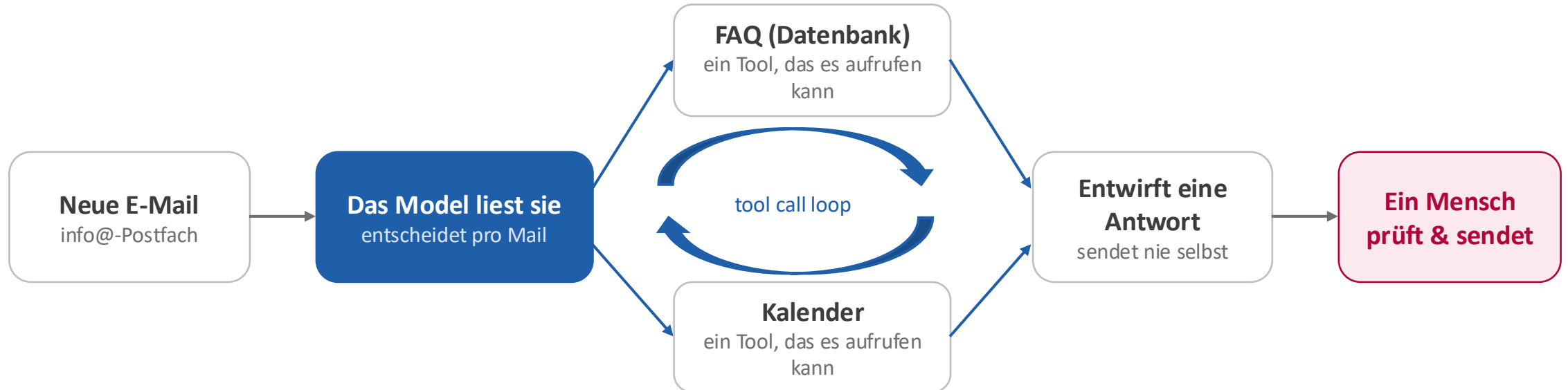


„Ein LLM-Agent führt Tools in einer Schleife aus, um ein Ziel zu erreichen.“

Drei Sorten von “AI Agents” (LLM)



Beispiel: Email KI-Assistent



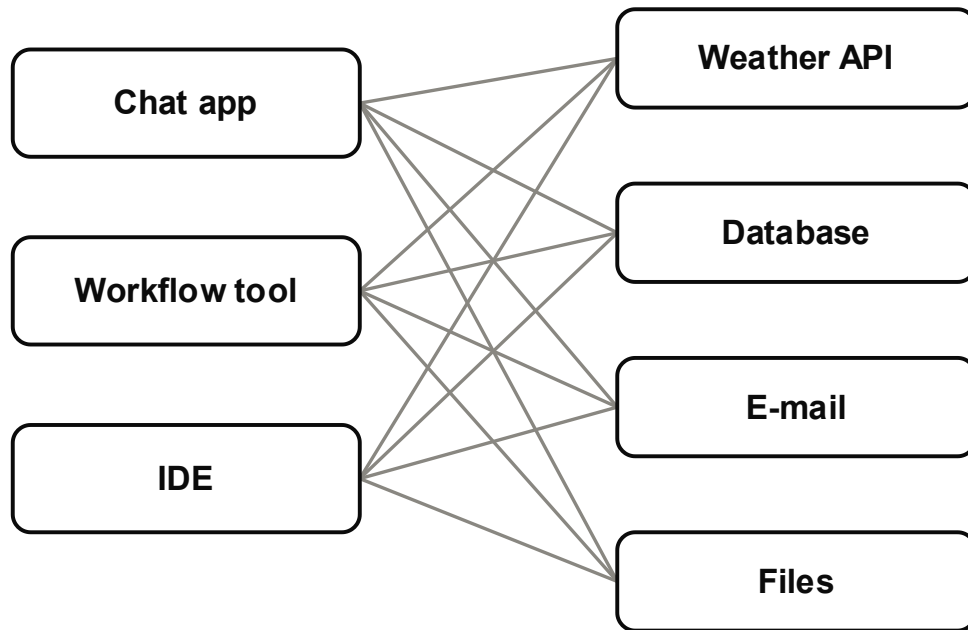
→ **Kategorie 1 oder 3**

(Je nachdem, wie viel Entscheidungsmacht dem Modell überlassen wird)

Model Context Protocol (MCP)

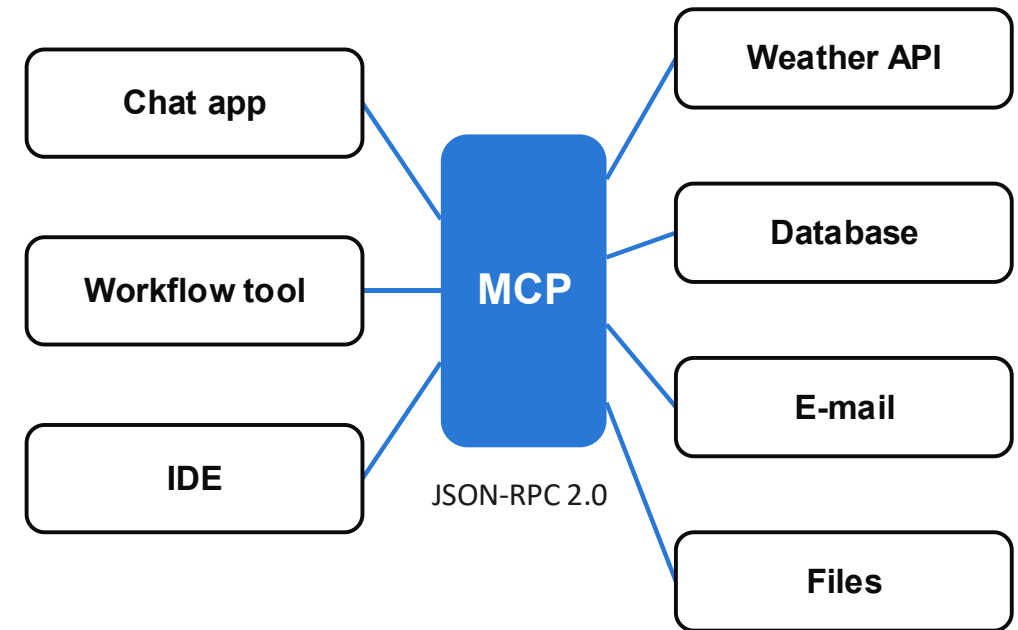
MCP ist ein Open-Source-Standard, um KI-Anwendungen mit externen Systemen zu verbinden.
„USB-C-Anschluss für KI-Anwendungen“.

Without MCP



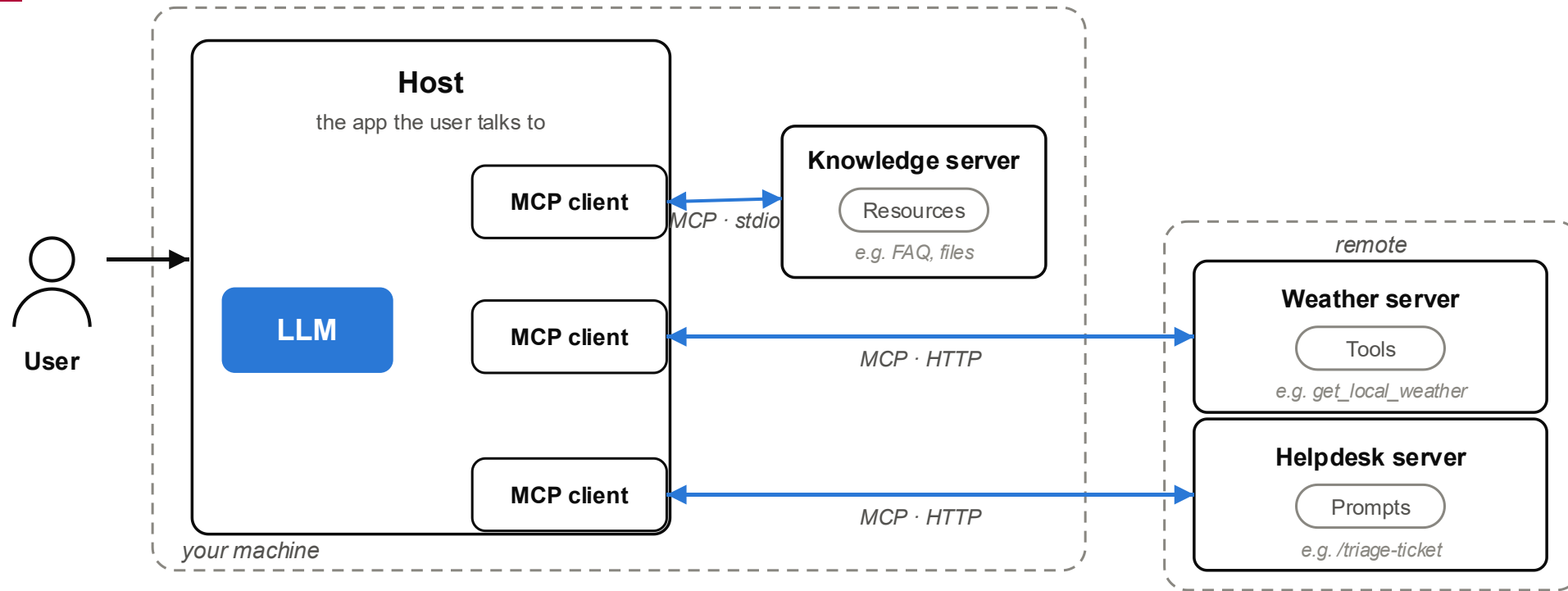
$3 \times 4 = 12$ point-to-point integrations

With MCP



$3 + 4 = 7$ connections, one protocol

Wie MCP funktioniert



Baustein	Was der Server anbietet	Beispiel
Resources	Daten, die es lesen kann	Dateien, Datenbanken, ...
Tools	Actions, die das Model aufrufen kann	<code>get_local_weather</code> , <code>draft_email</code> , ...
Prompts	vorgefertigte Abläufe	„dieses Ticket zusammenfassen & einordnen“

Wie wählt das Model ein tool aus?

```
name:      get_forecast
description: "Daily weather forecast for a city. Use for
             questions about rain, temperature or wind
             on a specific date."
inputs:    city (text), date (date)
```

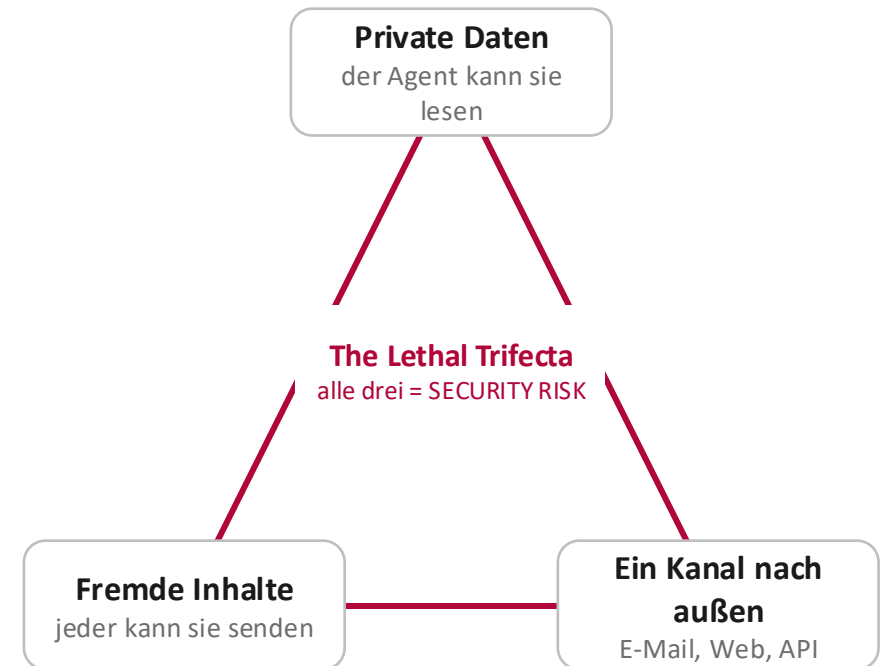


Descriptions und alles, was ein Tool zurückgibt, sind Text, der Ihren Agent steuert.

Sicherheit: Wem vertrauen Sie?

Ein verbundener Server handelt mit den Rechten, die Sie ihm gegeben haben.

Risiko	Was passieren kann
Zu weitreichende Rechte	der Server bekommt ein Admin-Token, obwohl er nur lesen musste
Offengelegte Geheimnisse	ein API-Key liegt im Klartext in einer Config-Datei
Prompt Injection	eine eingehende E-Mail versteckt Anweisungen, und der Agent führt sie aus
Tool Poisoning	eine Tool-Description versteckt Anweisungen, die niemand in der UI sieht
Rug Pull	ein geprüfter Server ändert nach einem Update seine Tool-Descriptions
Supply Chain	ein Server imitiert einen bekannten Anbieter und schickt jede E-Mail per BCC weiter



Kombiniert niemals mehr als zwei dieser Befugnisse!

Was kann passieren?

Mai 2025 · GitHub MCP *demonstriert*

Ein bösartiges öffentliches Issue bringt einen Agent dazu, Daten aus einem privaten Repo in einen öffentlichen Pull Request zu kopieren.

Prompt Injection + zu weit gefasstes Token

Quelle: Invariant Labs

<https://invariantlabs.ai/blog/mcp-github-vulnerability>

Sep. 2025 · postmark-mcp *in der Praxis*

Ein gefälschter E-Mail-Server verhält sich monatelang unauffällig, dann schickt er still jede E-Mail per BCC an eine externe Adresse.

Supply Chain

Quelle: Koi Security

<https://thehackernews.com/2025/09/first-malicious-mcp-server-found.html>

2025 · MCPoison · CVE-2025-54136 *in der Praxis*

Eine bereits genehmigte MCP-Config wird nachträglich verändert; Code läuft ohne erneute Freigabe.

Rug Pull bei vertrauter Config

Quelle: Check Point Research

<https://research.checkpoint.com/2025/cursor-vulnerability-mcpoison/>

Drei verschiedene Fehlerarten: ein gekapeter Agent · ein bösartiger Server · eine vertraute Config, die unbemerkt geändert wurde.

Risiken begrenzen

- 1 **Least Privilege** der Agent bekommt ein eigenes Konto, minimale Scopes, kurzlebige Keys.
- 2 **Sandbox** lokale Server in einem Docker-Container laufen lassen: begrenzt, was der Prozess erreicht (Dateisystem, Netzwerk, System), falls er sich falsch verhält.
- 3 **Human in the loop** ein Mensch gibt alles Unumkehrbare frei: senden, löschen, bezahlen, veröffentlichen.
- 4 **Rule of Two (Meta)** pro Agent höchstens 2 der 3 Trifecta-Eigenschaften; die dritte nur hinter einer Freigabe.
- 5 **Der Quelle vertrauen** verifizierte oder First-Party-Server bevorzugen; Updates wie Software-Updates behandeln.
- 6 **Logs führen** wenn etwas schiefgeht, wollen Sie wissen, was der Agent getan hat.

Gehen Sie davon aus, dass der Agent gekapert werden *kann*, und machen Sie das überlebbar.

Prüf-Checkliste für MCP-Sicherheit

Frage

- 1 **Wer stellt ihn bereit?** First-Party · verifiziert · unbekannt
 - 2 **Was kann er in Ihrem Namen tun?** nur lesen vs. unumkehrbar
 - 3 **Wohin gehen Ihre Daten?** lokaler Code vs. Remote-Cloud
 - 4 **Wird die Kombination gefährlich?** Trifecta / Rule of Two
 - 5 **Könnten Sie mit dem schlimmsten Fall leben?**
-

Urteil →



nutzen



mit Auflagen nutzen



nicht in diesem Kontext

Hilfsmittel: offizielle Registry · MCP Inspector · mcp-scan

Ein Eintrag ist keine Sicherheitszertifizierung.

Wie finde ich einen MCP Server?

Offizielle Registry

registry.modelcontextprotocol.io

gepflegt vom MCP-Projekt,
(Unübersichtlich)

Große Kataloge

- pulesemcp.com (+ use cases)
- github.com/mcp
- mcpservers.org
- smithery.ai

nach Anbieter, Kategorie und
Beliebtheit stöbern

Kataloge mit Sicherheitsbewertungen

- mcpsafe.org
- mcprisk.org

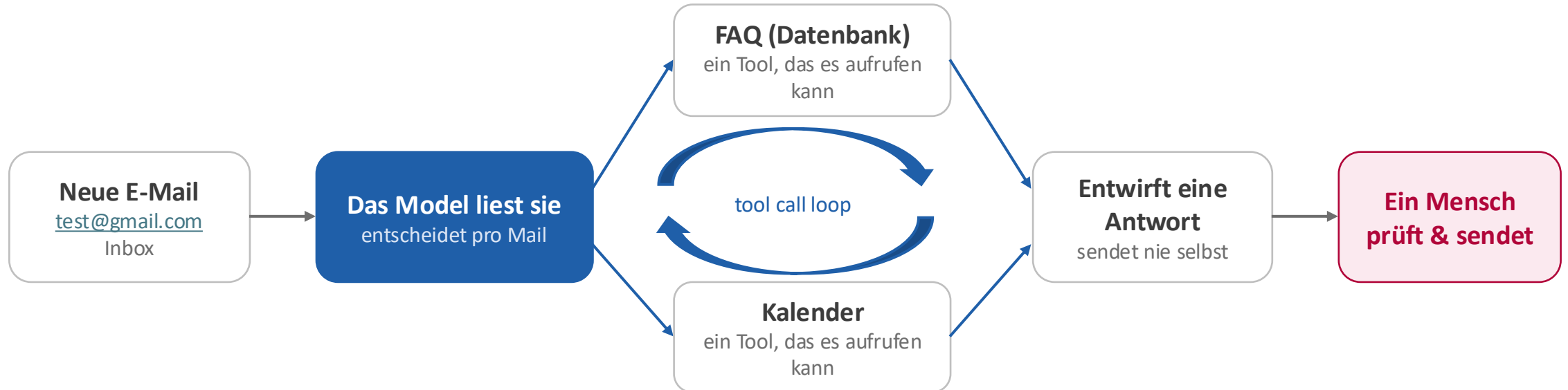
Offizielle Anbieter-Server

- Google
- Notion
- Figma
- Scalable Capital
- ...

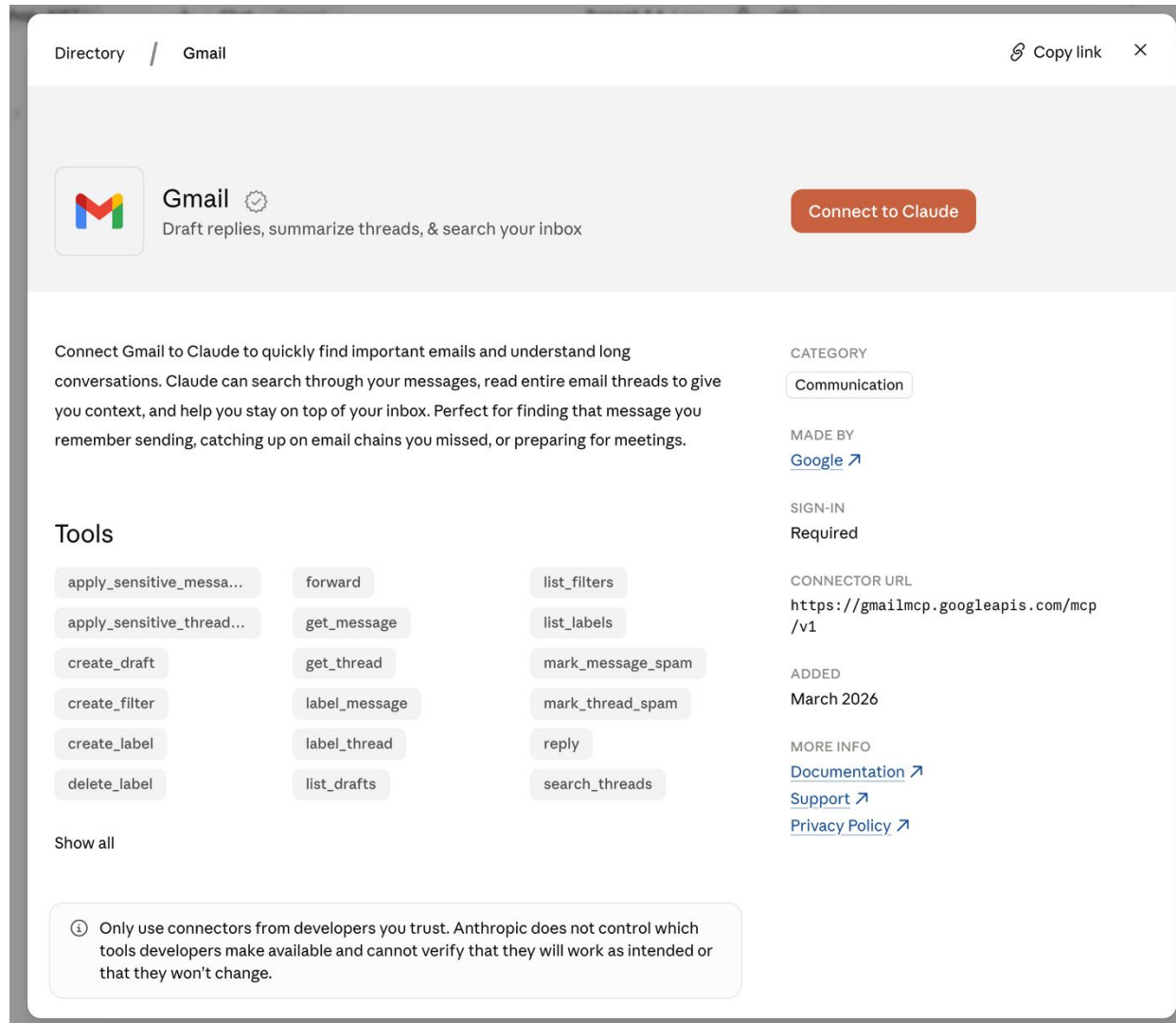
Anbieter liefern zunehmend
eigene Server

Erste Frage bei jedem Use Case: Existiert ein offizieller Server?

Demo: Connect Claude with Gmail and Google Calendar



Demo · Schritt 1: Server finden und bewerten



Worauf achten

Wer hat ihn gebaut?

Checkliste F1

Was kann er in Ihrem Namen tun?

Checkliste F2

Demo · Schritt 2: Mit Least Privilege verbinden

A · Gmail-Berechtigungsdialog

Über Google anmelden



Claude for Gmail möchte auf Ihr Google-Konto zugreifen

 kisz.test@gmail.com

Wählen Sie aus, worauf **Claude for Gmail** zugreifen darf

☐ Alle auswählen

 E-Mails und Einstellungen abrufen. [Zugriffsdetails ansehen](#)

☒

 Entwürfe verwalten und E-Mails senden. [Zugriffsdetails ansehen](#)

☒

 E-Mails über Ihr Gmail-Konto aufrufen, verfassen und senden. [Zugriffsdetails ansehen](#)

☐

Claude for Gmail vertrauen?

In der [Datenschutzerklärung](#) und den [Nutzungsbedingungen](#) von Claude for Gmail erfahren Sie, wie Claude for Gmail Ihre Daten verarbeitet und schützt.

Sie können in Ihrem [Google-Konto](#) jederzeit Änderungen an Ihren Angaben vornehmen.

Google unterstützt Sie dabei, [Daten sicher zu teilen](#).

Abbrechen

Weiter

Deutsch

Hilfe

Datenschutz

Nutzungsbedingungen

B · Google-Kalender-Berechtigungsdialog

Über Google anmelden



Claude for Google Calendar möchte auf Ihr Google-Konto zugreifen

 kisz.test@gmail.com

Wählen Sie aus, worauf **Claude for Google Calendar** zugreifen darf

☐ Alle auswählen

 Termine in allen Kalendern abrufen. [Zugriffsdetails ansehen](#)

☒

 Alle Kalender aufrufen und herunterladen, auf die Sie über Ihren Google Kalender Zugriff haben. [Zugriffsdetails ansehen](#)

☐

 Alle Kalender, die über Google Kalender verfügbar sind, aufrufen, bearbeiten, freigeben und endgültig löschen. [Zugriffsdetails ansehen](#)

☐

Claude for Google Calendar vertrauen?

In der [Datenschutzerklärung](#) und den [Nutzungsbedingungen](#) von Claude for Google Calendar erfahren Sie, wie Claude for Google Calendar Ihre Daten verarbeitet und schützt.

Sie können in Ihrem [Google-Konto](#) jederzeit Änderungen an Ihren Angaben vornehmen.

Google unterstützt Sie dabei, [Daten sicher zu teilen](#).

Abbrechen

Weiter

Deutsch

Hilfe

Datenschutz

Nutzungsbedingungen

Nur gewähren, was die Aufgabe braucht. Gmail: lesen + entwerfen. Kalender: nur lesen.

Demo · Schritt 3: Testen

The screenshot shows an email interface with two messages. The first message is from 'customer test' to 'an mich' (me), dated 'Fr., 4. Sept., 09:59 (vor 3 Tagen)'. The second message is from 'test kisz' to 'an customer.kisz.test', dated 'Fr., 4. Sept., 11:03 (vor 3 Tagen)'. The second message includes a red line pointing to a footer note: 'Dieser Entwurf wurde mit KI-Unterstützung erstellt. Ein Teammitglied hat den Inhalt geprüft und die E-Mail abgeschickt.'

customer test <customer.kisz.test@gmail.com> Fr., 4. Sept., 09:59 (vor 3 Tagen) ☆ 😊 ↩ ⋮
an mich ▾
Hallo,

wir sind ein kleines Unternehmen aus Potsdam und interessieren uns für KI-Schulungen.

Bieten Sie so etwas auch für Einsteiger an, und was würde das kosten?

Viele Grüße,
Max Mustermann

test kisz <kisz.test@gmail.com> Fr., 4. Sept., 11:03 (vor 3 Tagen) ☆ 😊 ↩ ⋮
an customer.kisz.test ▾

Guten Tag Herr Mustermann,

vielen Dank für Ihre Anfrage. Ja, wir bieten Workshops für Einsteiger an, auch für kleine Unternehmen und KMU. Das Angebot reicht von einsteigerfreundlichen Formaten bis hin zu Workshops zur Entwicklung eigener KI-Anwendungen.

Alle unsere Angebote sind kostenlos.

Eine Übersicht unserer aktuellen Veranstaltungen und die Möglichkeit zur Anmeldung finden Sie hier: [Workshops und Veranstaltungen](#).

Falls Sie vorab Fragen haben oder unsicher sind, welches Format am besten passt, können Sie gern an unserer [KI-Sprechstunde](#) teilnehmen. Die findet online in kleinen Gruppen statt und dient zum Kennenlernen.

Bei weiteren Fragen melden Sie sich gern.

Mit freundlichen Grüßen
KI-Servicezentrum Berlin-Brandenburg

Dieser Entwurf wurde mit KI-Unterstützung erstellt. Ein Teammitglied hat den Inhalt geprüft und die E-Mail abgeschickt.

Human-In-The-Loop

Ungelesene Mails -> Agent

- Frage → FAQ-Antwort
- Buchung → Kalender → freier Slot
- sonst → eskalieren

Es werden nur Entwürfe erstellt!

Jetzt Sie: Entwerfen Sie Ihren eigenen agentischen Workflow

Ca. 20 Minuten · Papier und Stift

- 1 **Eine wiederkehrende Aufgabe wählen**
- 2 **Das Arbeitsblatt ausfüllen** Idee, 2–3 Beispielanfragen, warum ein Agent?, warum ein MCP Server?
- 3 **Passende MCP-Server finden** registry.modelcontextprotocol.io, pulesemcp.com, github.com/mcp, mcp-servers.org, smithery.ai, mcpsafe.org, mcprisk.org, ...
- 4 **Jeden Server durch die Prüf-Checkliste schicken** Urteil ●●●
- 5 **Nächste Schritte zum Pilot notieren** Verantwortliche · Zugang · Freigabe

Danach: 3-Minuten-Pitches. Ihre Idee, Ihr(e) Server, Ihr Urteil.

kisz@hpi.de

hpi.de/kisz

Your opinion is
relevant!



QR code to feedback form

Gefördert durch:

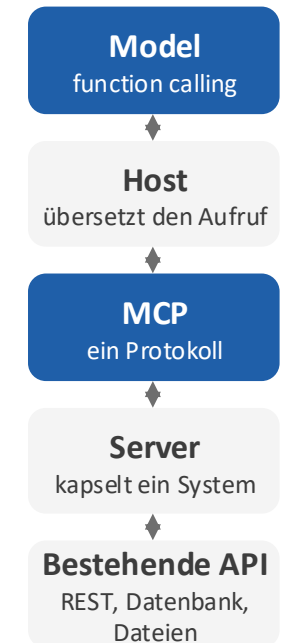


Bundesministerium
für Forschung, Technologie
und Raumfahrt



Backup · Ist das nicht einfach nur eine weitere API?

	Klassische API (REST, gRPC)	MCP
Vertrag	einer pro Service, jeder anders	ein festes Interface für jedes Tool
Integration	zur Entwicklungszeit: Doku lesen, Glue-Code schreiben	zur Laufzeit: tools/list → Model-Kontext
Nutzer	ein Entwickler	das Model, das Descriptions liest



Darunter ist es JSON-RPC; das Model macht weiterhin normales Function Calling, also **funktioniert jedes Model**.

Vorbilder: LSP (Editoren × Sprachen), ODBC (Apps × Datenbanken). Ein Server kapselt meist eine bestehende API: MCP sitzt vor Ihren Services, es ersetzt sie nicht.

Backup · Was tatsächlich über die Leitung geht

1 · Discovery: **tools/list**

```
// request
{ "method": "tools/list" }

// response
{ "tools": [ {
  "name": "get_forecast",
  "description": "Daily weather forecast
    for a city. Use for ...",
  "inputSchema": { "city": "string",
    "date": "string" }
} ] }
```

2 · Ausführung: **tools/call**

```
// request
{ "method": "tools/call",
  "params": { "name": "get_forecast",
    "arguments": { "city": "Berlin",
      "date": "2026-09-05" } } }

// response
{ "content": [ { "type": "text",
  "text": "Berlin, 5 Sept: 19 °C, light rain" } ] }
```

Reines JSON-RPC · Discovery zur Laufzeit · **die Description ist ein Prompt.**

inputSchema ist gewöhnliches JSON Schema. Der Host reicht Name, Description und Schema im nativen Function-Calling-Format an das Model weiter; das Model sieht MCP selbst nie.

Backup · Unter der Haube: MCP spricht JSON

Jede Nachricht zwischen Client und Server ist ein **JSON-Objekt** (Standard: **JSON-RPC 2.0**).

```
→ { "method": "tools/list" }    // Was kannst du?
← { "tools": [ { "name": "get_local_weather",
  "description": "Wettervorhersage für eine Stadt ...",
  "inputSchema": { "city": "string", "date": "string" } } ] }

→ { "method": "tools/call",    // Bitte ausführen
  "params": { "name": "get_local_weather",
    "arguments": { "city": "Berlin", "date": "2026-09-09" } } }
← { "content": [ { "type": "text",
  "text": "Berlin, 9. Sept: 19 °C, leichter Regen" } ] }
```

- **Sprachunabhängig** – jeder Client spricht mit jedem Server (Python, TypeScript, Go ...)
- **Strukturiert & prüfbar** – Parameter sind per JSON Schema typisiert, das Model erzeugt gültige Aufrufe
- **Passt zum Function Calling** – LLMs sprechen ohnehin JSON Schema, also 1:1-Abbildung
- **Menschenlesbar** – im MCP Inspector direkt nachvollziehbar

Das Model schreibt kein JSON-RPC – der Host übersetzt zwischen Model-Aufruf und Protokoll.